The Sr. Phishermen's White Team Documentation

About Us

Combustion Dynamics Corporation (CDC) is a manufacturing and consumer products company preparing to launch its new energy drink line, Fahrenheit, following the recent acquisition of Rankine. The organization manages a mixed technology environment that includes legacy systems, internal infrastructure, proprietary formulation data, and pre-launch operational platforms, supported by both internal networks and external services. CDC's mission is to maintain a secure and stable environment leading up to the product launch by protecting sensitive information, ensuring system integrity, and mitigating risks from external threats and potential insider activity.

Table of Contents

About Us **0**
Public Services **2**
Network Architecture **2**
Network Topology 2
WAN Rules 3
NAT: Port Forward 4
Servers **6**
Active Directory (Domain Controller) 6
Ticketing Machine (TICKETS) 6
Management Backend (MGMT) 7
Admin User Interface (ADMIN) 7
Website (WWW) 8

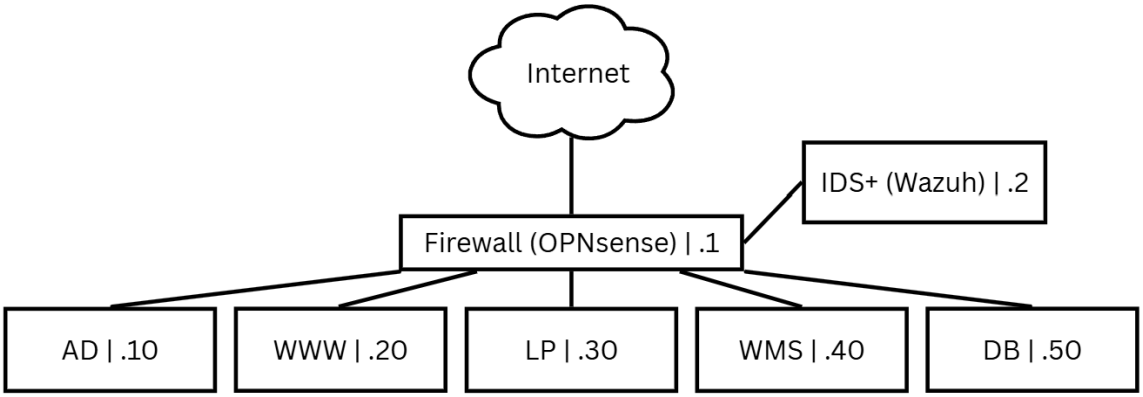
Public Services

The following Public Services are available:

Domain Name	IP	Port(s)
ad.team1.isucdc.com	64.5.53.10	LDAP (389), RDP (3389)
www.team1.isucdc.com	64.5.53.20	SSH (22), HTTP (80)
lp.team1.isucdc.com	64.5.53.30	SMB (445), RDP (3389)
wms.team1.isucdc.com	64.5.53.40	SSH (22), HTTP (8080)
db.team1.isucdc.com	64.5.53.50	SSH (22), MySQL (3306)

Network Architecture

Network Topology



The provided network topology represents a centralized, flat-segmented architecture anchored by an OPNsense firewall functioning as the primary control plane for ingress, egress, and internal traffic mediation. All external connectivity originates from the Internet and is funneled through the firewall (.1), which enforces NAT, filtering, and routing policies before permitting access to internal hosts. A dedicated IDS sensor (.2), running Wazuh, is positioned adjacent to the firewall to monitor traffic flows and generate alerts on suspicious or anomalous activity, providing visibility into both perimeter and internal threats.

Behind the firewall, the internal network consists of multiple service-oriented hosts sharing the same logical subnet. The AD server (.10) operates as the domain controller, providing centralized authentication, directory services, and likely Kerberos/LDAP functionality for the environment. The WWW server (.20) hosts the externally accessible web application, acting as the primary user interaction point and a common initial attack surface. The LP system (.30) supports printing and likely exposes SMB or similar file-sharing services, introducing additional lateral movement opportunities if compromised.

The WMS server (.40) functions as the core application backend, orchestrating business logic and interacting with both the web server and database. The DB server (.50) hosts the central data store, likely MySQL, servicing queries from WWW and WMS. Given this design, the database represents a high-value target, with compromise enabling full data exfiltration or manipulation.

Unlike a segmented architecture, this topology places all internal systems within a single broadcast domain behind the firewall. While this simplifies routing and service communication, it significantly increases lateral movement risk once an attacker gains initial access. The firewall primarily protects against external threats, but east-west traffic between internal hosts

appears unrestricted, making internal compromise propagation more feasible.

The inclusion of Wazuh provides detection capability, but not prevention. As such, the security posture relies heavily on host-based hardening and monitoring rather than network isolation. Overall, the architecture supports necessary service interactions but exposes risk through limited internal segmentation, emphasizing the importance of endpoint security, logging, and rapid detection of anomalous behavior.

WAN Rules

Allow/ Deny	Src	Src. Port	Destination External IP	Destination Internal IP	Dest. Port	Description
Allow	*	*	64.5.53.10	10.0.0.10	389	LDAP → AD
Allow	*	*	64.5.53.10	10.0.0.10	3389	RDP → AD
Allow	*	*	64.5.53.20	10.0.0.20	80	HTTP → WWW
Allow	*	*	64.5.53.20	10.0.0.20	22	SSH → WWW
Allow	*	*	64.5.53.30	10.0.0.30	3389	RDP → LP
Allow	*	*	64.5.53.30	10.0.0.30	445	SMB → LP
Allow	*	*	64.5.53.40	10.0.0.40	22	SSH → WMS
Allow	*	*	64.5.53.40	10.0.0.40	8080	HTTP → WMS
Allow	*	*	64.5.53.50	10.0.0.50	22	SSH → DB
Allow	*	*	64.5.53.50	10.0.0.50	3306	MySQL → DB
Deny	*	*	*	*	*	Implicit deny

WAN rules control which inbound traffic from the public internet is permitted to reach your network. When a packet arrives on one of your external IPs (64.5.53.x), the firewall checks these rules first. If a rule explicitly allows the source, protocol, and destination port, the traffic is permitted to proceed; if not, it is blocked immediately. WAN rules, therefore, serve as the front gate of the network–only traffic you explicitly authorize, such as RDP to the AD server or HTTPS to the web server, is allowed through. Everything else is dropped before it ever reaches the internal LAN.

NAT: Port Forward

Interface	Protocol	Destination Address	Ports	Description
LAN	TCP	*	*	Anti-Lockout Rule
WAN	TCP	64.5.53.10	389	LDAP → AD
WAN	TCP	64.5.53.10	3389	RDP → AD
WAN	TCP	64.5.53.10	80	HTTP → WWW
WAN	TCP	64.5.53.20	22	SSH → WWW
WAN	TCP	64.5.53.20	3389	RDP → LP
WAN	TCP	64.5.53.30	445	SMB → LP
WAN	TCP	64.5.53.30	8080	HTTP → WMS
WAN	TCP	64.5.53.40	22	SSH → WMS
WAN	TCP	64.5.53.40	22	SSH → DB
WAN	TCP	64.5.53.50	3306	MySQL → DB

NAT rules handle the translation and forwarding of that approved inbound traffic to the correct internal system. Once the WAN rule allows traffic to enter, the NAT rule determines which internal IP and port should receive it. For

example, a NAT rule might forward 64.5.53.40:3389 on the WAN interface to 10.0.0.40:3389 inside the LAN. NAT is what makes internal services reachable externally while keeping internal addressing hidden.

Servers

Active Directory (Domain Controller)

Operating System: Windows Server 2016
About: The Active Directory server is the Domain Controller for the environment. It authenticates users, manages domain accounts, and allows all scenario users to log in across the network. All other machines rely on this server for LDAP authentication and directory services.

Security Changes (Machine):

- Reduced cached credential storage to prevent credential theft
- Hardened NTLM authentication (set LmCompatibilityLevel to 5)
- Enforced SMB signing to mitigate NTLM relay attacks
- Reviewed and validated domain user accounts for legitimacy
- Removed Domain Users group from Domain Admins group

Website (WWW)

Operating System: Alma Linux 8
About: This machine hosts the company's public website. Customers can sign up, view loyalty points,manage their account information, place store orders, and view current orders.
Security Changes (Codebase):

- Added password hashing for new registrations and password changes

- Updated SQL queries to use parameterized statements
- Added allowlist for dynamic lookup keys in get_user_by to prevent arbitrary column injection
- Changed default user creation path to non-admin
- Removed automatic admin promotion from login_required decorator
- Added @login_required protection on /get_payment_info endpoint
- Disabled Flask debug mode
- Centralized config into environment file

Security Changes (Machine):

- Removed overly-permissive elevated-user permissions in /etc/sudoers

Label Printer (LP)

Operating System: Windows Server 2019

About: This machine hosts, stores, and creates the labels for outgoing orders. The labels are also viewable or printable from this machine.

Security Changes (Codebase):

- Sanitize untrusted JSON fields before injection into ZPL
- Switched placeholder substitution from regex-based -replace to deterministic string .Replace(...)
- Replaced shell execution with Java's File.write(), preventing command injection
- Added a barcode format validation and path traversal check to prevent path traversal vulnerabilities

Security Changes (Machine):

- Disabled Guest account to prevent unauthenticated access
- Hardened NTLM authentication (fixed LmCompatibilityLevel from 0 to 5)
- Identified and terminated suspicious service listening on port 1337

- Restricted SMB share access to specific domain group (WarehouseUsers)
- Removed overly permissive NTFS permissions (eliminated BUILTIN\Users access)
- Applied least-privilege NTFS permissions for label processing workflows

Warehouse Management System (WMS)

Operating System: Ubuntu 24.04

About: This is the warehouse backend for the WWW Storefront. It connects to the database and performs CRUD operations for stock and order management. It also generates files for label printing by retrieving and consolidating details from both the WWW frontend and the database.

Security Changes (Codebase):

- Updated SQL queries to use parameterized statements
- Centralized config into environment file

Security Changes (Machine):

- Removed malicious cron job resetting root password (chpasswd backdoor)

Database (DB)

Operating System: Ubuntu 16.04

About: This server hosts the central MySQL database for the WWW Storefront and Warehouse Management System (WMS). It stores and manages WWW and WMS data including user authentication records, loyalty points, payment information, shipping details, inventory items, and order transactions.

Security Changes:

- Detected and removed tampered /bin/nc binary used for deception/persistence

- Restored legitimate system binary for accurate network diagnostics